



SECURITY INSTRUCTION - NETWORK SEGMENTATION



INSTRUCTION'S OBJECTIVE

This Instruction sets requirements to ensure the **protection of information in networks and its supporting information processing facilities.**



SCOPE

This instruction applies to all AXA entities network solutions for AXA operating entities, holding companies, and external organizations connecting to AXA network.



Contents

Security Instruction - Network segmentation	1
1 Introduction	3
1.1 Main Stakeholders: Roles & Responsibilities	3
1.2 Key definitions	3
2 Detailed Requirements	3
2.1 Workplace Zone	4
2.2 Production Zone	4
2.2.1 Internal network sub-zone	5
2.2.2 External network sub-zone	6
2.3 Communication between zones	8
2.4 Management Zone	9
2.5 Development Sandbox Zone	9
2.6 Development Tools Zone	10
2.7 Pre-Production	10
2.8 External	11
3 Reporting	11
4 Document management and control	11



1 Introduction

1.1 Main Stakeholders: Roles & Responsibilities

Recommended Roles and responsibilities are defined in [4].

Entities shall ensure that they inform their third parties of any obligations they may have to comply with the requirements outlined in this document.

1.2 Key definitions

Please see the “Security Instructions Glossary of terms” for definitions [1].

2 Detailed Requirements

1. Operating entities shall segment their network(s) from other Entity networks and have the ability to monitor any inter Entity communications enabling the detection and prevention of suspicious activity and intrusions.
2. An Operating entities networks shall be segmented. Each segment shall be aligned to one of the following seven network zones:

Network Zone	Description
Workplace	The network segment where all end user devices reside
Production	The network segment for production IT systems and applications
Management	The network segment that is used to provide out of band management of the IT systems
Development Tools	The network area that houses all the development tools such as source code repositories
Development sandbox	The network where developers can create and deploy systems and software as required by their entity
Pre-production	The network area for testing IT systems and applications
External	Non-AXA managed networks like the internet, third party networks

3. The connection(s) between the above network zones shall be secured by an access control mechanism.
4. Where the mechanism deployed to segment an Operating Entities network zones allows the inter zone network traffic to be monitored. This traffic shall be collated and processed to detect suspicious activities.
5. Each entity shall document their network segmentation and the deployed security controls.



6. The effectiveness of the network segmentation shall be security tested on an annual basis. This testing includes, and is not limited to, firewall rule base reviews.
7. Any application that is utilised by multiple Operating entities shall be located in a shared network that is accessible by all AXA employees and contractors.
8. For all access control services operated by a 3rd party, first line shall retain evidence and analysis that the 3rd party can't modify their own access level
9. Legacy systems do not have to follow the Network Segmentation requirements.
 - a. Legacy systems do have to provide a migration or decommissioning plan approved by risk governance.
 - b. Legacy systems are defined as systems that cannot support the minimum requirements for segmentation mechanisms in the current deployment.

2.1 Workplace Zone

The workplace zone is the network segment where the AXA managed employee devices reside. Typically, the workplace zone will consist of a collection of local area networks and wide area networks connecting various AXA offices. AXA managed notebooks connected through an AXA VPN are considered part of the Workplace Zone.

1. Some IT solutions need servers in local AXA offices, connected to the workplace zone. This is permitted upon the condition that those servers are only providing local services for the workplace zone. Pre-approved exceptions : DHCP servers, printer servers, or local authentication servers
2. Any other servers or devices that store or process AXA data deployed within the workplace zone shall be approved by the **Entity CSO**
3. The workplace zone is only reachable from the Management Zone.
4. If an Entity wishes to deploy a Wi-Fi solution for visitors to AXA, this Wi-Fi network shall be considered as an External network zone. A logically separate network solution shall be deployed only allowing visitors access to internet. To protect AXA from the mis-use of this network all guest access to the Internet shall be logged and recorded.

2.2 Production Zone

The production zone is where the significant majority of all Entity applications and supporting IT systems shall be located.

1. An Operating Entities production systems and applications shall be segmented into the following network sub-zones:
 - a. Internal network sub-zone - Internally facing systems used by AXA employees and visible and/or accessible from AXA networks only
 - b. External network sub-zone - Externally facing systems and applications that run on



systems that are visible and/or accessible from external networks

2. Using the entity approved security risk assessment methodology and processes, a security risk assessment shall be performed, for any inter entities communication. The risks shall be documented to identify any additional security controls. Any residual risks shall be managed and documented by the entities risk committee.
3. When a system is internally and externally facing, it shall be placed in the external segment and the controls for external systems shall be applied. When the application architecture separates the internal and external facing frontend on different systems, they can be in their own segment with their own controls but the database shall reside in the external segment. If an application security gateway is used the database can reside on the internal segment.

2.2.1 Internal network sub-zone

1. The internal network sub-zone shall be segmented. Logical network areas shall be created for systems processing or storing information where the significant majority of data is classified as:
 - a. Public, Internal, and Confidential - This network sub-zone allows free network communication among applications
 - b. Secret - this network sub-zones shall only allow specifically authorized communications between applications
2. The segmentation required are outlined in the table below:

Sub-Zone	Data classification	Segmentation within Zone
Internal	Public, Internal & Confidential (Internal-PIC)	No additional security segmentation is required.
	Secret (Internal - S)	• Using the entity approved security risk assessment methodology and processes, a security risk assessment shall be performed. • Up to 3 functional layers can be deployed to segment various elements of an application. The application Architect shall determine the appropriate number of functional layers and controls. An appropriately configured access control mechanism shall be implemented between each functional layer. • Network segmentation shall be implemented within this network sub-zone to stop any communication to another application within the sub-zone. • If two applications require to communicate to each other, the communication shall go via an access control mechanism.



3. The internal network zone shall not be directly accessible from the internet. To access the internal network zone from the internet, all network traffic shall be inspected and restricted to only those network protocols specifically required for the application to operate correctly. Preventing the creation of tunnels between AXA internal networks and the Internet using AXA DNS servers (by segregating DNS servers used for internal systems and those used for Internet systems). To access systems and applications within the internal network zone, an access control mechanism shall be deployed (as a minimum) at each of the following network connection points between the network zones:

- internet to external
 - external to internal
- or
- internet to workplace
 - workplace to internal

2.2.2 External network sub-zone

1. The external network sub-zone shall be segmented. Logical network areas shall be created for systems processing or storing information where the significant majority of data classified as:
 - a. “Public and Internal” and “Confidential” – these network sub-zones shall only allow specifically authorised communications between applications only
 - b. Secret - this network sub-zone requires a bespoke security solution to be created.
 - c. The additional controls and segmentation required within the “Public, Internal”, “Confidential” and “Secret” zones are outlined in the table below:

Sub-Zone	Data classification	Segmentation within Zone	Additional controls for external access
External	Public and Internal (External-PI)	- Within this network sub-zone, network segmentation shall be implemented. - Communications shall be secured by the placement of an appropriately access control mechanism, limiting communications to only those specifically required to enable the application to operate.	All internet facing communication shall be secured by a: - access control mechanism; - A monitoring solution to detect and prevent intrusions. - DDoS detection and prevention solution
	Confidential (External-C)	Public and Internal segregation plus: Using the entity approved security risk assessment methodology and processes, a	All internet facing communication shall be secured as ‘External Public and Internal’ plus:



Sub-Zone	Data classification	Segmentation within Zone	Additional controls for external access
		security risk assessment shall be performed. Up to 3 functional layers can be deployed to segment various elements of an application. The application Architect shall determine the appropriate number of functional layers and controls. An appropriately configured access control mechanism shall be implemented between each functional layer.	- Web Application Firewall (WAF), for web-applications - Application Security Gateway, for web-APIs
	Secret (External-S)	As external confidential plus the design shall be approved by Group Security Architecture	All internet facing communication shall be secured as 'External Confidential' plus The Entity shall ensure that the information security risk assessment and the risk management decisions are validated by entity CSO and the entity Risk Committee.

- All IT system and application administration interfaces shall not be accessible from the internet or any other external network. This includes (but not limited to) SSH, websites urls used for administration purposes etc.
- External facing applications used by customers and/or third parties shall not use the internal AXA Microsoft Active Directory domains for authentication purposes.
- External facing IT systems shall not be added as member servers or domain controllers to any Microsoft Active Domains that also contain any internal AXA servers, desktops and/or laptops.
- No Microsoft Active Directory trusts shall be established from external Microsoft Active Directory domains to internal AXA Microsoft Activity Directory domains, such that external credentials are trusted by the internal AXA domain.
- The architecture of external facing IT that is used by two or more of the following user communities - customers, third parties and/or employees, shall have additional security controls to segregate different user communities. This design shall be approved Group Security Architecture.
- Communication from external facing systems to internal facing systems shall be restricted to



those network protocols specifically required. This communication flow shall flow through a mediation solution (e.g. proxy, API gateway). The security risks shall be assessed and documented. The decisions based on security risk assessment shall be validated by the entity CSO and Risk Committee.

2.3 Communication between zones

Many of our applications share data, to enable these applications to share data the following rules shall be adhered to:

		Data Classification Zone	Destination*							
			Entity-A				Shared Zone			
			Internal-PIC	Internal-S	External-PI	External-CS	Internal-PIC	Internal-S	External-PI	External-CS
Source*	Entity-A	Internal-PIC	Free	I	I	I	Free	II	I	II
		Internal-S	Free	I	I	I	Free	II	I	II
		External-PI	I	I	I	I	I	II	I	II
		External-CS	I	I	I	I	I	II	I	II
	Entity-B	Internal-PIC	II	II	II	II	Free	II	I	II
		Internal-S	II	II	II	II	Free	II	I	II
		External-PI	II	II	II	II	I	II	I	II
		External-CS	II	II	II	II	I	II	I	II
	Shared Zone	Internal-PIC	II	II	II	II	Free	I	I	I
		Internal-S	II	II	II	II	Free	I	I	I
		External-PI	II	II	II	II	I	I	I	I
		External-CS	II	II	II	II	I	I	I	I

Notion shall be taken that the 'source' and 'destination' are located in any AXA managed network. This could be a mix of 'Public Cloud', CoreIT and 'Private Cloud'. (e.g. connection from "public cloud internal PIC from Entity-A in North America" to "Shared CoreIT internal-PIC in Europe").

Free No controls needed, traffic can flow freely within the same entity or to Shared.

I Communications shall be secured by the placement of an appropriately configured firewall or application security gateway, limiting communications to only those specifically required to enable the application to operate.

II Controls mentioned at 'I' and:

A security risk assessment shall be performed and documented to identify any additional security controls. Any residual risks shall be accepted by the Entity security risk owner(s). Each entity shall ensure that the risk assessment and the risk management decisions shall be validated by the Entity CSO(s) and Risk Committee.

For new inter-application communication, the preferred method of securing the communication is using an access control mechanism.



2.4 Management Zone

Within each data centre, there shall be a management network. In each data centre, entities providing IT services shall utilize the same management network infrastructure. Logical segmentation of the management network is allowed. AXA management networks in different data centres should be connected with no additional security controls required.

Outlined below are the rules for the set up and configuration of the management network:

1. All system (servers, routers, switches, firewalls, etc.) within the Data Centre shall be connected to the Management Zone network via an appropriate management port/interface. The systems shall be configured to allow only management connections via the management network. No administrative interfaces shall be accessible in any other zone defined in this document.
2. The connection between the Workplace Zone and the Management Zone shall be secured with an access control mechanism, and the network connection shall be monitored to detect and prevent intrusions.
3. Access from the workplace zone to the management zone shall be strictly controlled by the deployment of appropriate security controls only allowing authorized users access to bastion hosts on the management zone.
4. Only bastion hosts are allowed to access any other network zone from the Management Zone.
5. Multi Factor Authentication shall be deployed to control access to the management zone.
6. The management zone network shall be configured to inherently prevent communication between systems connected to the management network. Communications to and from IT administration and management systems (e.g. backup systems, network management systems, privilege user access management systems, etc.) to systems being administrated via the management network shall be restricted to only the required protocols.

2.5 Development Sandbox Zone

The development zone is a special area of the network for the development of new applications and IT services.

1. It is up to the Entity to define network segmentation within the Development Sandbox.
2. If a developer or IT administrator needs to deploy new system images to assist in the development of the application or IT service, the system image shall be deployed within this zone
3. Any AXA data used within this zone shall be anonymized
4. If the sandbox is accessible from the Internet, it shall only be accessible using entity approved remote access solutions that complies to the security requirements outlined in the “Security Instructions – Infrastructure Security Baseline” [2].
5. The sandbox shall only be accessible from partially-managed networks, workplace and development Tool zones after passing through an access control mechanism with proper monitoring



6. Services deployed in the sandbox shall only accessible from within the sandbox
7. It is preferred that systems located in this zone have appropriate security hardening applied
8. It is preferred that security patches are applied to systems located in this zone

2.6 Development Tools Zone

The development tools zone is an area of the network where the system with the development tools shall reside.

1. All development tools (e.g. central code repository) installed on systems shall be installed within this zone
2. Access to the development tools zone shall be controlled, only allowing those users that require access to perform their duties
3. Multi Factor Authentication is mandatory for access from the internet
4. Where an application is being developed by multiple Entities a shared development zone shall be used
5. There are no general network segmentation requirements

2.7 Pre-Production

This is the area of the network designed to test new applications and IT services.

1. Each entities pre-production network zone shall be configured with the same zones and subzones as defined above for production
2. Read-Access from pre-production to production zone 'internal facing, Public, Internal and Confidential 'or 'external facing 'Public and Internal' systems shall be restricted to those network protocols specifically required
3. Read-Access from pre-production to 'internal facing, Secret' or 'external facing Confidential and Secret' systems shall be restricted to those network protocols specifically required. An security risk assessment shall be performed to identify any additional security controls. Any residual risks shall be approved by the **Entity CSO(s)** and Risk Committee where the production applications reside
4. Pre-production shall not have write-access to production
5. Utilising the production zone for pre-production activities shall be approved by the **Entity CSO**



2.8 External

All non-AXA managed networks, including but not limited to internet and third-party networks, are considered external. The various external networks can be used for a variety of different purposes; each purpose will have its own risk-profile. At least the following categories should be taken into consideration:

Internet Services	Consumption of services from the internet (e.g. APIs, Salesforce, etc)
Internet Customer	Provide services to AXA customers (individuals and corporates) via the internet (e.g. web-sites and APIs)
External Developer	Developer working remotely and connecting to the AXA network via the internet

3 Reporting

Regular assurance activities shall be performed as described in “Group Security Instructions – Fundamental Requirements”[3].

4 Document management and control

Document control

Document Location:	https://axa365.sharepoint.com/sites/onesecurity/Shared%20Documents/Forms/AllItems.aspx Folder “7 –Security Instructions”
Review Frequency:	Annually
Document Sensitivity	Internal

Contacts for this document

E-Mail	Entity
Instructions.Security@axa.com	Group Security

Approval history

Version	Approved by	Approved Date
	Voting members of the Group Information Risk Board (GIRB)	3 rd May 2016
	Voting members of the IT Board	14 th / 15 th June 2016
V1.6	Security Leadership Team	March 2019
V1.7	Security Leadership Team	March 2020



Version	Approved by	Approved Date
V1.8	Security Leadership Team	October 2020
V1.9	Security Leadership Team	March 2021
V1.9.01	Security Leadership Team	March 2022

Revision history

Version No.	Version Date	Summary of Change	Changed By
V1.0	Jun 2016	First draft	Edward Hamilton
V1.1	Nov 2016	Update to reflect Public and Private cloud technologies	Timo Muller
V1.2	Jan 2017	Update to clarify some English language used within the document	Edward Hamilton
V1.3	April 2017	Update to clarify positioning of database in a split external/internal application	Alex Hafey
V1.4	June 2017	Update after Group Risk review	Edward Hamilton
V1.43	Sept 2017	Minor update after review by Internal audit	Edward Hamilton
V1.45	February 2018	Review with Group Risk	Edward Hamilton
V1.5	February 2018	Release	Edward Hamilton
V1.6	February 2019	New Format and PWG feedback	Victoria Melvin / Diego Alvarado
V1.7	February 2020	Added requirement for vendors Links and Owner updated	Alex Hafey / Diego Alvarado
V1.8	October 2020	SABSA review, removed specific technologies partially enabling use of ZeroTrust mechanisms	Alex Hafey
V1.9	December 2020	Format updates	Diego Alvarado
V1.9.01	November 2021	Updates in sections 2, 2.2, and 2.2.2 IS Risk statements removed	Alex Hafey Diego Alvarado
	March 2024	Reviewed. No updates done	Diego Alvarado



Reference documents

Document	Details
[1] Security Instructions - Glossary of terms	Definitions of terms. Document can be found at: https://axa365.sharepoint.com/sites/onesecurity/Shared%20Documents/Forms/AllItems.aspx Folder "7 -Security Instructions"
[2] Security Instructions - Infrastructure Security Baseline	Infrastructure Security Baseline Document can be found at: https://axa365.sharepoint.com/sites/onesecurity/Shared%20Documents/Forms/AllItems.aspx Folder "7 -Security Instructions"
[3] Group Security Instructions – Fundamental Requirements	Group Security Instructions – Fundamental Requirements. Document can be found at: https://axa365.sharepoint.com/sites/onesecurity/Shared%20Documents/Forms/AllItems.aspx Folder "7 -Security Instructions"
[4] Security Instructions – Roles and Responsibilities RACI - Full	Security Instructions – Roles and Responsibilities RACI – Full. Summary of roles and responsibilities for Security Instructions Document can be found at: https://axa365.sharepoint.com/sites/onesecurity/Shared%20Documents/Forms/AllItems.aspx Folder "7 -Security Instructions/03. Guidelines"

Note: Some links don't work if clicked on the document. Please copy them into the browser URL bar instead.